

redmineflux_devops — Bug Report

Suite 09 — Security & Compliance | 4 open bugs | Redmine 6.0.9 | Generated 2026-05-28

Plugin: **redmineflux_devops** | Environment: Local Docker (http://localhost:3008) | Status: **Open**

BUG-RDV-056	High	FOSSA license ingestion stores all licenses as "NOASSERTION" / "unknown" risk regardless of payload
Steps to Reproduce	1. POST /projects/phoenix-platform/devops/fossa_webhook with valid HMAC-SHA256 signature. 2. Use payload {"dependencies":[{"name":"lodash","license":"MIT"}]}. 3. Check license records in /devops_licenses.	
Expected Result	License name extracted correctly (MIT, GPL-3.0). Risk mapped: GPL-3.0 → High, MIT/Apache/BSD → Low.	
Actual Result	All records stored as license_name = "NOASSERTION" and risk_level = "unknown". LicenseRiskMapper fails to extract SPDX ID from any payload format.	
Affected TCs	TC-RDV-395 (FAIL), TC-RDV-396 (FAIL)	

BUG-RDV-057	High	SSRF guard not implemented — private and metadata URLs accepted in sonarqube_host_url field
Steps to Reproduce	1. Navigate to Project > DevOps > Settings. 2. Enter SSRF test URL in SonarQube Server URL field: http://169.254.169.254/latest/meta-data/ 3. Click Save and reload.	
Expected Result	URL rejected with validation error "URL must not be a private, loopback, or cloud metadata address". HTTP 422 returned.	
Actual Result	SSRF URL accepted and saved without error. Settings page reloads with success state. Field value persists. No SSRF guard validation applied.	
Affected TCs	TC-RDV-411 (FAIL)	

BUG-RDV-058	High	XSS payload in release description is not sanitized — script executes on release detail page
Steps to Reproduce	1. Edit release v2.0.0 description. Enter: <script>alert(XSS)</script>Malicious release notes. 2. Save. 3. Navigate to release detail page /devops_releases/1.	
Expected Result	<script> tag stripped or HTML-escaped. No JavaScript executes. Text rendered safely.	
Actual Result	<script>alert(XSS)</script> stored unescaped and rendered as-is. Alert dialog fires when release detail page loads. Stored XSS — any user viewing the release triggers script execution.	
Affected TCs	TC-RDV-412 (FAIL)	

BUG-RDV-059	High	Developer role can access Security Vulnerabilities page — view_security_scans permission not enforced
Steps to Reproduce	1. Use dev_user API key. GET /projects/phoenix-platform/devops_vulnerabilities. 2. Observe HTTP response status.	
Expected Result	HTTP 403 Forbidden for Developer role. "Security" tab not visible in DevOps nav for Developers.	
Actual Result	HTTP 200 returned for dev_user (Developer). Security Vulnerabilities page loads fully. view_security_scans permission check missing from controller.	
Affected TCs	TC-RDV-416 (FAIL)	